

OWASP For API

Start Assignment

- Due Saturday by 11:59pm
- Points 500
- Submitting a text entry box or a file upload

OWASP For API

This OWASP lab series cover the most critical security risks across modern cyber attacks against: web apps, APIs, and LLM/GenAI applications. They are related to each other: web apps remain the user-facing with most attack surfaces, APIs expose business logic and data to services and partners, and LLMs/agents introduce new attack surfaces and failure modes. Together, they provide a defense-in-depth view of application security grounded in OWASP's guidance.

a) Overview

This lab series focuses on API specific failures that often occur even in otherwise secure web apps, because APIs introduce object level authorization complexity, high automation, and machine to machine trust assumptions.

OWASP API Security Top 10:

1. API1: Broken Object Level Authorization (BOLA)

Object ID based access control is missing or flawed, letting users access other users' objects.

2. API2: Broken User Authentication

Auth mechanisms are misimplemented, enabling account takeover, token abuse, or impersonation.

3. API3: Excessive Data Exposure

APIs return more data than needed, exposing sensitive fields and relying on clients to filter.

4. API4: Lack of Resources and Rate Limiting

No limits on requests and payloads enables DoS and brute forcing.

5. API5: Broken Function Level Authorization (BFLA)

Role and permission checks are missing for actions, enabling unauthorized operations.

6. API6: Mass Assignment

Clients can set object properties they should not control by sending extra fields.

7. **API7: Security Misconfiguration**

Insecure defaults, verbose errors, missing headers, open storage, and risky platform settings.

8. **API8: Injection**

Untrusted input is interpreted in SQL, command, XML, etc, causing data access or execution.

9. **API9: Improper Assets Management**

Old versions, undocumented endpoints, and exposed non production APIs create hidden risk.

10. **API10: Insufficient Logging and Monitoring**

Missing API telemetry and alerting prevents timely detection and response.

b) NotebookLM learning approach, with guidance for each of the 10

Use NotebookLM after each module to translate the scenario into an API security habit:

- What should be enforced server side, every time
- What should be validated at the gateway
- What should be monitored for abuse

Sample guidance:

1. **BOLA**

Ask: “How do I implement object level authorization? Provide examples using resource ownership checks and policy based access control.”

2. **Broken User Authentication**

Ask: “List robust token handling practices and the top mistakes that cause auth bypass in APIs.”

3. **Excessive Data Exposure**

Ask: “How do I design response schemas to avoid overexposure? Explain field level filtering and DTO patterns.”

4. **Lack of Resources and Rate Limiting**

Ask: “Give me a rate limit strategy, including per user, per IP, and per token, plus payload and pagination limits.”

5. **BFLA**

Ask: “How do I validate function level permissions consistently across endpoints? Provide a rule set approach.”

6. **Mass Assignment**

Ask: “What are safe binding patterns? Give allowlist and schema validation examples and explain why they work.”

7. **Security Misconfiguration**

Ask: “Give a hardening checklist for API gateways, CORS, headers, error handling, and environment separation.”

8. Injection

Ask: “Provide secure input handling for SQL and command execution use cases, plus examples of exploit patterns to test against.”

9. Improper Assets Management

Ask: “Give an inventory and versioning checklist: documentation, deprecation, discovery, and exposure controls.”

10. Insufficient Logging and Monitoring

Ask: “What do I log for API abuse detection and incident response? Include auth failures, authorization failures, and anomaly detection.”

NotebookLM link: <https://notebooklm.google.com>

c) Submission requirements

Pick 10 and submit 10 screenshots and 10 paragraphs for this lab.

Screenshots

Provide 1 final screenshot per topic showing the completed module or final validated outcome. Reflection paragraphs

Provide 10 paragraphs, one per topic.

Each paragraph should include:

- What the risk means in your own words
- What you did or observed in the lab scenario

Lab link: <https://application.security/free/owasp-top-10-API>

Have fun and please use student lounge for second opinion or questions!